

SGSI-UNCP

Marco Conceptual del Sistema de Gestión de Seguridad de la Información

Documento Base del Sistema de Gestión
de Seguridad de la Información

Universidad Nacional del Centro del Perú

Índice

- 1 Concepto y Principios del SGSI
 - 1.1 Definición
 - 1.2 Principios Fundamentales
 - 1.3 Objetivos del SGSI en la UNCP
- 2 Modelo Conceptual del SGSI
 - 2.1 Ciclo PHVA (Planificar-Hacer-Verificar-Actuar)
 - 2.2 Arquitectura del SGSI
- 3 Información Digital y Física
 - 3.1 Tratamiento Diferenciado
 - 3.2 Controles para Información Física
- 4 Estructura del SGSI
 - 4.1 Mapa de Documentos del SGSI
 - 4.2 Ciclo de Vida de la Información Documentada
 - 4.3 Roles y Responsabilidades
- 5 Activos de Información
 - 5.1 Clasificación de la Información
 - 5.2 Ciclo de Vida del Activo de Información
- 6 Modelo de Transición AS-IS a TO-BE
 - 6.1 Diagnóstico de Madurez por Dimensión
 - 6.2 Hoja de Ruta de Implementación
- 7 Integración con el PGTD
 - 7.1 Articulación SGSI-PGTD
 - 7.2 Proyectos Relacionados
- 8 Referencias Normativas

Organización: Universidad Nacional del Centro del Perú (UNCP)

Referencia Normativa: ISO/IEC 27001:2022, ISO/IEC 27002:2022, ISO/IEC 27000:2018

Documentos Relacionados: D-SGSI-00 (Marco Terminológico y Normativo), D-SGSI-01 (Contexto Estratégico), D-SGSI-02 (Alcance), PGTD-UNCP 2026-2030

Propósito: Establecer el modelo conceptual que integra los elementos del SGSI, sus relaciones, principios fundamentales y ciclo de vida, adaptado al contexto de la UNCP.

1. Concepto y Principios del SGSI

1.1. Definición

Un Sistema de Gestión de Seguridad de la Información (SGSI) es un conjunto de políticas, procedimientos, controles y recursos interdependientes que una organización establece para gestionar la seguridad de su información, basado en la norma ISO/IEC 27001:2022 y adaptado a su contexto específico.

A diferencia de soluciones puntuales de seguridad (un firewall, un antivirus), el SGSI opera como un **sistema de gestión integral** que abarca personas, procesos y tecnología, con un enfoque basado en riesgos y mejora continua (ciclo PHVA — Planificar, Hacer, Verificar, Actuar).

1.2. Principios Fundamentales

Principio	Definición	Aplicación en UNCP
Confidencialidad	La información no está disponible ni se revela a personas, procesos o sistemas no autorizados.	Datos personales de 10,000 estudiantes protegidos bajo Ley N° 29733. Notas, grados y títulos accesibles solo por personal autorizado.
Integridad	La información es completa, exacta y no ha sido alterada de forma no autorizada.	Registros académicos (ERP ADESA) y actas de notas deben ser inalterables. La investigación científica requiere integridad garantizada.
Disponibilidad	La información es accesible y utilizable por usuarios autorizados cuando lo requieran.	Campus virtual (Moodle), portal académico y correo institucional deben tener disponibilidad 24/7 durante el ciclo académico. La OGTD4 del PGTD fija meta de 99.5 % de uptime.

1.3. Objetivos del SGSI en la UNCP

Los objetivos del SGSI se derivan de los Objetivos de Gobierno Digital (OGTD) del PGTD-UNCP 2026-2030:

Objetivo SGSI	OGTD Relacionado	Indicador	Meta al 2028
Proteger la confidencialidad e integridad de los datos académicos y de investigación	OGTD3 (SGSI/ISO 27001)	Porcentaje de procesos incorporados al SGSI	90 %
Garantizar la disponibilidad de los servicios digitales críticos	OGTD4 (Infraestructura y Green IT)	Uptime de servicios críticos	99.5 %
Cumplir con el marco legal peruano de protección de datos y confianza digital	OGTD3 + Marco de Confianza Digital (D.S. 126-2025-PCM)	No conformidades legales detectadas en auditoría	0
Reducir el riesgo de incidentes de seguridad mediante controles preventivos y detectivos	OGTD3	Tiempo medio de respuesta a incidentes	< 24 horas
Elevar la cultura de seguridad en la comunidad universitaria	OGTD6 (Competencias digitales)	Porcentaje de trabajadores capacitados en seguridad	100 %

2. Modelo Conceptual del SGSI

2.1. Ciclo PHVA (Planificar-Hacer-Verificar-Actuar)

El SGSI se implementa siguiendo el ciclo de mejora continua PHVA, alineado con las cláusulas 4 a 10 de ISO/IEC 27001:2022:

Fase	Cláusulas ISO 27001	Actividades Clave en UNCP
Planificar (Plan)	4 (Contexto), 5 (Liderazgo), 6 (Planificación)	Análisis de contexto (D-SGSI-01), definición de alcance (D-SGSI-02), política de seguridad (D-SGSI-03), evaluación de riesgos (D-SGSI-04), SoA (D-SGSI-05)
Hacer (Do)	7 (Soporte), 8 (Operación)	Implementación de controles (A.5-A.8), capacitación (P-SGSI-08), gestión de incidentes (P-SGSI-02), control de acceso (P-SGSI-03)
Verificar (Check)	9 (Evaluación del desempeño)	Auditorías internas (P-SGSI-09), monitoreo de KPIs (R-SGSI-03), revisión por la dirección
Actuar (Act)	10 (Mejora)	Acciones correctivas, mejora continua, actualización del SoA

2.2. Arquitectura del SGSI

Fase PHVA	Componente	Cláusula ISO	Documentos Asociados	Función
PLAN	Política de Seguridad	5 (Liderazgo)	D-SGSI-03, ACT-SGSI-01	Establece la dirección estratégica, los objetivos y el compromiso de la alta dirección con el SGSI
PLAN	Contexto de la Organización	4 (Contexto)	D-SGSI-01, D-SGSI-02, D-SGSI-06, D-SGSI-07	Determina las cuestiones internas y externas, las partes interesadas y el alcance del SGSI
PLAN	Liderazgo	5 (Liderazgo)	ACT-SGSI-01, D-SGSI-03	Define roles, responsabilidades y la autoridad para el SGSI
PLAN	Planificación	6 (Planificación)	D-SGSI-04, D-SGSI-05, R-SGSI-01, R-SGSI-02	Evalúa riesgos, define objetivos de seguridad y establece el plan de tratamiento
DO	Soporte	7 (Soporte)	P-SGSI-00, P-SGSI-08	Provee recursos, competencias, concientización, comunicación e información documentada

Fase PHVA	Componente	Cláusula ISO	Documentos Asociados	Función
DO	Operación	8 (Operación)	P-SGSI-02 al 07, POL-SGSI-01 al 07, Controles A.5-A.8	Implementa y ejecuta los controles de seguridad y los procesos operativos Monitorea, mide, analiza, audita y revisa el desempeño del SGSI Gestiona no conformidades, implementa acciones correctivas y mejora continuamente
CHECK	Evaluación del Desempeño	9 (Evaluación)	P-SGSI-09, R-SGSI-03, R-SGSI-04	
ACT	Mejora	10 (Mejora)	Acciones Correctivas	

Ciclo de retroalimentación: Los resultados de la fase CHECK alimentan la fase ACT, cuyas salidas retroalimentan la fase PLAN, cerrando el ciclo PHVA de mejora continua.

3. Información Digital y Física

3.1. Tratamiento Diferenciado

El SGSI de la UNCP abarca la información en **todos sus formatos**, reconociendo que la seguridad debe ser integral e independiente del soporte:

Tipo de Información	Características	Ejemplos en UNCP	Controles Aplicables
Digital	Almacenada en sistemas, bases de datos, archivos electrónicos. Respaldo, cifrado, control de acceso lógico.	ERP ADESA (23 módulos), Moodle 4.1, DSpace, Microsoft 365, SIGA, SIAF	A.8 (Activos), A.9 (Acceso), A.10 (Criptografía), A.12 (Operaciones), A.13 (Comunicaciones)
Física (papel)	Documentos impresos, actas, expedientes. Almacenamiento en archivos físicos.	Actas de notas, resoluciones rectorales, contratos, expedientes de grados y títulos, tesis impresas	A.7 (RRHH — inducción), A.11 (Seguridad física), A.8.3 (Manejo de medios)
Transmitida	Comunicaciones orales, videoconferencias, telefonía.	Clases virtuales (Teams), reuniones del CGD, llamadas telefónicas	A.7 (Concientización), A.13 (Seguridad en comunicaciones)

3.2. Controles para Información Física

La UNCP, por su naturaleza como institución educativa pública, gestiona un volumen significativo de información en soporte físico que debe ser protegida:

Control ISO 27002	Aplicación en UNCP	Estado Actual
A.7.3 — Concientización, educación y capacitación	Personal de archivo y secretarías debe conocer procedimientos de manejo seguro de documentos físicos	No implementado
A.8.3 — Manejo de soportes de almacenamiento	Procedimientos para almacenamiento, transporte y eliminación de documentos físicos confidenciales	Parcial (no formalizado)
A.11.1.1 — Perímetro de seguridad física	Control de acceso a edificios, vigilancia, cámaras en archivos centrales y tesorería	Parcial
A.11.1.2 — Controles de acceso físico	Puertas con llave, tarjetas de proximidad o biométricos en áreas sensibles	Parcial
A.11.1.4 — Protección contra amenazas externas	Extintores, detección de incendios, control de humedad en archivos	No verificado
A.11.2.9 — Escritorio limpio y pantalla limpia	Documentos sensibles guardados bajo llave al retirarse; bloqueo automático de pantalla	No implementado
A.11.2.7 — Eliminación segura	Trituradoras certificadas para documentos confidenciales; destrucción certificada de activos	No implementado

4. Estructura del SGSI

4.1. Mapa de Documentos del SGSI

Tipo	Prefijo	Cantidad	Función
Documento de Referencia	D-SGSI	10	Marco conceptual, contexto, alcance, política, metodología, SoA, mapa de procesos, guía de controles, estrategia de certificación
Procedimiento	P-SGSI	9	Control documental, incidentes, accesos, cambios, continuidad, proveedores, eliminación segura, capacitación, auditoría
Política	POL-SGSI	7	Desarrollo seguro, uso aceptable, clasificación, proveedores, móviles, contraseñas, seguridad física
Registro	R-SGSI	5	Lista maestra, inventario de activos, matriz de riesgos, KPIs, programa de auditoría
Formato	F-SGSI	6	Solicitud de acceso, asistencia, baja de usuario, RAC, eliminación segura, bitácora de acceso
Acta	ACT-SGSI	1	Compromiso de la alta dirección

4.2. Ciclo de Vida de la Información Documentada

Etapas	Descripción	Responsable	Registro Asociado
Creación	Elaboración del documento según la plantilla establecida	Autor designado	R-SGSI-00 (Lista Maestra)
Revisión	Verificación técnica y normativa del contenido	Oficial de Seguridad	—
Aprobación	Validación formal por la autoridad competente	Comité de Gobierno Digital / Rector	ACT-SGSI-01
Publicación	Difusión en el repositorio documental del SGSI	OTI	R-SGSI-00
Distribución	Comunicación a las partes interesadas	Oficial de Seguridad	—
Acceso	Consulta controlada según nivel de clasificación	Usuarios autorizados	F-SGSI-01 (Solicitud de acceso)
Revisión periódica	Evaluación de vigencia y actualización	Oficial de Seguridad	P-SGSI-09 (Auditoría)
Actualización	Modificación controlada del contenido	Autor designado	P-SGSI-04 (Gestión de cambios)
Eliminación	Destrucción segura cuando pierde vigencia	Oficial de Seguridad	F-SGSI-05 (Acta de eliminación)

4.3. Roles y Responsabilidades

Rol SGSI	Responsabilidad Principal	Designación en UNCP
Titular de la Entidad	Responsabilidad última del SGSI. Preside el Comité de Gobierno Digital. Aprueba la política de seguridad.	Rector de la UNCP

Rol SGSI	Responsabilidad Principal	Designación en UNCP
Comité de Gobierno Digital	Dirige, evalúa y supervisa la transformación digital y el SGSI. Aprueba el SoA, los resultados de auditorías y la revisión por la dirección.	Resolución N° 1862-R-2023
Oficial de Seguridad y Confianza Digital	Lidera el SGSI operativamente. Coordina la implementación de controles, gestiona incidentes y reporta al Comité. Es el punto de contacto ante la SGTD.	R. N° 2143-R-2023
Responsable de OTI	Implementa los controles técnicos. Administra la infraestructura de seguridad (firewalls, SIEM, backups).	OTI (2 profesionales)
Oficial de Gobierno de Datos	Gestiona la calidad, integridad y uso de los datos institucionales. Define políticas de datos.	Por designar (Compromiso 20 CGR)
Oficial de Datos Personales	Asegura el cumplimiento de la Ley N° 29733. Atiende solicitudes de ejercicio de derechos ARCO.	Por designar
Responsables de Proceso	Aseguran que los controles de seguridad se apliquen en sus procesos. Reportan incidentes.	Decanos, Directores, Jefes de Oficina
Todos los Colaboradores	Obligación de conocer y aplicar la política de seguridad. Reportar incidentes y vulnerabilidades.	~1,700 docentes y administrativos

5. Activos de Información

5.1. Clasificación de la Información

La UNCP clasifica su información según su nivel de sensibilidad y criticidad, en línea con el control A.5.12 de ISO 27002:

Nivel de Clasificación	Descripción	Ejemplos en UNCP	Medidas de Protección
Público	Información destinada al conocimiento general, sin restricción de acceso	Oferta académica, noticias institucionales, resoluciones publicadas en transparencia	Controles básicos de integridad y disponibilidad
Interno	Información de uso interno que no debe ser divulgada externamente	Directivas, comunicaciones internas, manuales de procedimientos	Control de acceso por roles, marcado de documentos
Confidencial	Información sensible cuya divulgación no autorizada causaría daño a la UNCP o a terceros	Datos personales de estudiantes y trabajadores (Ley N° 29733), calificaciones, expedientes de grado	Cifrado, control de acceso estricto, registro de accesos, MFA
Secreto / Restringido	Información altamente sensible cuya divulgación causaría daño severo	Estrategias de certificación, claves criptográficas, resultados de auditorías internas, credenciales de administración	Cifrado en reposo y tránsito, acceso con doble factor, registro detallado de accesos, segregación de funciones

5.2. Ciclo de Vida del Activo de Información

Etapas	Descripción	Controles Clave
Identificación	Registro del activo en el inventario con su clasificación, propietario y criticidad	R-SGSI-01 (Inventario de Activos), A.5.9
Almacenamiento	Protección según clasificación: cifrado, control de acceso, respaldo	A.8.24 (Cifrado), A.8.13 (Backups), A.9.4 (Restricción de acceso)
Uso	Acceso y procesamiento por personal autorizado según sus funciones	A.9.2 (Gestión de acceso), A.9.3 (Responsabilidades de acceso)
Transporte	Traslado físico o transmisión electrónica entre sedes o hacia la nube	A.8.3 (Manejo de medios), A.13.2 (Transferencia de información)
Eliminación	Destrucción segura cuando el activo pierde vigencia o utilidad	P-SGSI-07 (Eliminación Segura), F-SGSI-05

6. Modelo de Transición AS-IS a TO-BE

6.1. Diagnóstico de Madurez por Dimensión

Dimensión	AS-IS (2026)	TO-BE (2028)	Brecha
Políticas de seguridad	Dispersas, no formalizadas, sin política general aprobada	Política SGSI aprobada por rectorado, comunicada y entendida por toda la UNCP	Crítica
Gobernanza	CGD formalizado pero sin reuniones periódicas. Oficial de Seguridad designado.	CGD activo con reuniones trimestrales. Oficial de Seguridad con equipo dedicado.	Media
Gestión de riesgos	No existe metodología formal de gestión de riesgos de seguridad	Metodología implementada (D-SGSI-04), matriz de riesgos actualizada semestralmente	Crítica
Control de acceso	Usuarios compartidos, contraseñas débiles, sin MFA generalizado	Acceso por roles (RBAC), MFA obligatorio para todos los sistemas críticos, política de contraseñas (POL-SGSI-06)	Crítica
Seguridad de red	Sin segmentación en facultades, firewall perimetral obsoleto sin licencias	Microsegmentación ZTNA, firewalls renovados con licencias vigentes, SD-WAN entre 4 sedes	Crítica
Monitoreo	Sin SIEM, detección manual de incidentes	SIEM (Wazuh / Microsoft Sentinel), SOC básico, detección automatizada de amenazas	Crítica
Backups	Backups sin validación periódica, sin respaldo off-site	Backups inmutables en Huawei Cloud, probados mensualmente, DRP documentado	Alta
Concientización	Programa mínimo o inexistente	Programa permanente de capacitación, phishing simulado trimestral, inducción obligatoria	Crítica
Cumplimiento normativo	Parcial (Ley N° 29733, D.L. N° 1412)	Cumplimiento auditado, reportes a CGR y PCM, alineación con Marco de Confianza Digital	Alta
Mejora continua	No existe ciclo de mejora formal	Auditorías internas trimestrales, revisión por dirección anual, acciones correctivas documentadas	Crítica

6.2. Hoja de Ruta de Implementación

Horizonte	Logros Clave	Nivel de Madurez Esperado
Corto plazo (2026)	Política de seguridad aprobada, inventario de activos completo, MFA implementado, primera campaña de concientización, renovación de firewalls	1.800
Mediano plazo (2027)	SIEM operativo, segmentación ZTNA en sedes principales, integración PIDE, 50 % de procesos en SGSI, capacitación al 100 % del personal	2.500
Largo plazo (2028)	Auditoría de certificación ISO 27001:2022, 90 % de procesos en SGSI, SOC consolidado, gobierno de datos implementado	3.500

7. Integración con el PGTD

7.1. Articulación SGSI-PGTD

El SGSI no es un sistema aislado; se articula con los instrumentos de gestión de la UNCP:

Instrumento de Gestión	Relación con el SGSI
PEI 2024-2030	El SGSI contribuye al logro de los objetivos estratégicos institucionales relacionados con calidad, modernización y transformación digital
PGTD 2026-2030	El SGSI es el proyecto PGTD-01, alineado con los 6 OGTD y los desafíos de seguridad
Mapa de Procesos (Nivel 0 y 01)	Define los procesos que serán incorporados al SGSI (meta: 90 % al 2028)
Plan de Continuidad Operativa 2024	Se actualizará para alinearse con el control A.17 (Continuidad) del SGSI
SCI (Control Interno)	El SGSI refuerza el componente de control de información del SCI, en línea con la Directiva N° 006-2019-CG/INTEG
Plan Anual de Contrataciones (PAC)	Los proyectos de seguridad (renovación de firewalls, SIEM, ZTNA) se programan en el PAC

7.2. Proyectos Relacionados

Proyecto PGTD	Descripción	Presupuesto	Relación con SGSI
PGTD-01	Implementación del SGSI basado en ISO 27001	S/ 850,000	Proyecto principal — núcleo del SGSI
PGTD-02	Portal único e identidad digital (SSO)	S/ 650,000	Control A.9 (Acceso), A.13 (Comunicaciones)
PGTD-04	Modernización de infraestructura TI	Por definir	Controles A.11 (Física), A.12 (Operaciones), A.13 (Red)
PGTD-06	Gestión de incidentes de seguridad informática	Por definir	Control A.16 (Gestión de incidentes)

8. Referencias Normativas

Norma / Documento	Descripción	Relación con el SGSI
ISO/IEC 27000:2018	Vocabulario y fundamentos de SGSI	Terminología base del sistema
ISO/IEC 27001:2022	Requisitos para un SGSI	Norma de referencia — estructura del SGSI
ISO/IEC 27002:2022	Guía de controles de seguridad	Base para los controles del Anexo A
ISO/IEC 27005:2018	Gestión de riesgos de seguridad	Metodología de evaluación de riesgos (D-SGSI-04)
Ley N° 29733	Ley de Protección de Datos Personales	Cumplimiento legal (A.18)
D.S. N° 016-2024-JUS	Nuevo Reglamento de la Ley N° 29733	DPIA, IA, transferencias internacionales
D.L. N° 1412	Ley de Gobierno Digital	Marco normativo de gobierno digital
D.S. N° 029-2021-PCM	Reglamento de la Ley de Gobierno Digital	Condiciones para gobierno digital
D.S. N° 098-2025-PCM	Modificación del D.S. N° 029-2021-PCM	Identidad digital, interoperabilidad
D.S. N° 126-2025-PCM	Marco de Confianza Digital	Confianza digital como pilar del SGSI
D.S. N° 115-2025-PCM	Reglamento de la Ley N° 31814 (IA)	Auditoría de algoritmos, supervisión humana
D.S. N° 103-2023-PCM	Política Nacional de Transformación Digital al 2030	Alineación con política nacional
R.S. N° 005-2018-PCM/SGTD	Lineamientos para formulación del PGTD	Estructura y contenido mínimo del PGTD
R.S. N° 001-2025-PCM/SGTD	Lineamiento de accesibilidad digital (WCAG 2.2)	Accesibilidad de servicios digitales
Directiva N° 001-2025-PCM/SGTD	Consumo seguro de servicios PIDE	Medidas de seguridad para interoperabilidad
Resolución N° 322-2026-CG	Plan de Gobierno y Transformación Digital CGR	Directrices para entidades sujetas a control
Directiva N° 006-2019-CG/INTEG	Sistema de Control Interno	Integración SCI-SGSI